



GESTÃO DA INFORMAÇÃO

AULA 5



Profª Adriana Bastos da Costa



CONVERSA INICIAL

Como sabemos, a gestão da informação é um processo composto por várias etapas e não é algo estático, pois novas necessidades de informação surgem a todo momento. Já discutimos que, portanto, é preciso estar preparado para atender a essas necessidades de forma mais ágil possível, e que a competitividade das empresas depende da agilidade de fornecer informações completas, precisas e confiáveis, e de se fazer uma boa gestão do conhecimento.

Nesta aula vamos discutir um pouco mais sobre segurança da informação e a importância desse assunto para as empresas de todos os ramos de negócio.

TOP – SEGURANÇA DA INFORMAÇÃO

Já pararam para pensar que a informação e o conhecimento são bens de grande valor para uma empresa? Quanto mais informação organizada e melhor ela souber usar essas informações na forma de conhecimento, mais vantagem ela terá em relação a seus concorrentes. Se isso é verdade, podemos entender por que existem pessoas que vivem de roubar informações, não é mesmo?

Já ouviram falar em *hackers*? Pois é, por incrível que pareça, passou a ser uma profissão. Cada vez mais empresas estão contratando profissionais especializados em segurança da informação, seja para buscar soluções seguras para seus negócios, seja para tentar encontrar falhas ou vulnerabilidades em seus negócios.

Quando falamos em segurança da informação, existe uma norma ISO que é especializada no assunto e direciona as boas práticas que devem ser seguidas para minimizar os riscos relacionados a problema de segurança. Estamos falando da norma ISO/IEC 27000 (ISO/IEC 27000..., S.d.). De acordo com a ISO/IEC 27000, segurança é a minimização do risco associado às atividades de computação, incluindo a interconexão entre computadores e demais aspectos físicos e humanos. É importante definir uma política de segurança, com o objetivo de definir os controles lógicos e físicos necessários para assegurar um determinado nível de disponibilidade dos sistemas, confiabilidade dos dados e servir de referência para as ações de treinamento dos usuários e demais procedimentos de segurança. Mas, mesmo tomando as medidas de proteção



necessárias, não existe segurança absoluta. Ou seja, sempre poderão existir vulnerabilidades.

As normas da família ISO/IEC 27000 estruturam o que chamamos de Sistema de Gestão de Segurança da Informação (SGSI), tendo como as normas mais conhecidas as ISO 27001 e ISO 27002. Ou seja, são várias normas, todas relacionadas com segurança da informação que, juntas, cuidam de assuntos relacionados à segurança de dados digitais ou sistemas de armazenamento eletrônico. O SGSI busca uma forma de segurança para todos os tipos de dados e informações de uma empresa e possui atributos básicos como confidencialidade, integridade e disponibilidade

É sempre bom lembrar que os conceitos relacionados com a segurança da informação vão além de questões tecnológicas, pois existem várias ameaças à segurança em uma empresa, que podem envolver, por exemplo, danos materiais, vazamento de informações, violação da integridade, uso indevido de recursos e dados, interceptação de informações e interrupção do serviço. Vocês podem pensar em outras ameaças? Tenho certeza que sim. Mas o nosso foco aqui serão as ameaças que envolvem a segurança da informação em si.

Saiba mais

Acharam esse assunto interessante? É um tema muito atual. Acesse o *link* a seguir e leia um artigo que mostra a importância que a segurança da informação tem para as empresas:

ROMIO, D. Como executivos devem investir em segurança da informação? **CIO**, 14 ago. 2019. Disponível em: <<https://cio.com.br/como-executivos-devem-investir-em-seguranca-da-informacao/>>. Acesso em: 23 abr. 2020.

ROLÊ 1 – CONFIDENCIALIDADE, INTEGRIDADE E DISPONIBILIDADE

Vamos fazer um resumo do que estudamos até o momento? Já discutimos sobre o que é um sistema, sobre os sistemas de informação, sobre a gestão da informação e sobre a importância de se ter uma informação correta e completa no momento de seu uso. Além disso, já discutimos também sobre como fazer a gestão adequada do conhecimento. Agora que já temos as informações organizadas, precisamos discutir como cuidar da segurança dessas informações.



Alguns conceitos básicos sobre esse assunto precisam estar bem entendidos. Vamos lá:

- Ativo de informação: qualquer elemento que tenha valor para uma organização;
- Valor do ativo: quantificação de perda de determinado ativo quando esse tem sua confidencialidade, integridade ou disponibilidade afetadas;
- Vulnerabilidade: falha no ambiente que ameace algum ativo;
- Ameaça: possibilidade de exploração de uma vulnerabilidade;
- Impacto: resultado da concretização de uma ameaça contra a vulnerabilidade de um ativo.

A segurança da informação é uma disciplina que envolve um conjunto de medidas necessárias e tem como objetivo garantir seus princípios básicos, que são a confidencialidade, a integridade e a disponibilidade das informações de uma organização ou indivíduo, de forma a preservar as informações de acordo com necessidades específicas. Como forma de buscar a proteção da informação, as medidas de segurança definidas devem minimizar os riscos de perda ou acessos indevidos.

Vamos detalhar o que significa confidencialidade, integridade e disponibilidade?

1.1 Confidencialidade

É um princípio de segurança que garante que os dados disponíveis em uma empresa somente sejam acessados por pessoas autorizadas. Até mesmo fatos simples, como conversas no elevador, restaurantes ou outros lugares públicos sobre assuntos confidenciais de trabalho, disponibilizando assim a informação para todos à sua volta, podem ser um problema muito sério.

1.2 Integridade

É um princípio de segurança que garante que dados e programas de computador (código) somente sejam modificados por pessoas ou atividades autorizadas. A integridade considera ainda todas as possíveis causas de modificação, incluindo falhas de *hardware* e *software*, eventos ambientais e intervenção humana. O grande problema, quando falamos de integridade dos dados, é a dificuldade de encontrar o problema, pois a informação acessada



pode estar completa e aparentemente confiável, só que errada ou inconsistente, o que gera muita confusão para os negócios.

1.3 Disponibilidade

É o princípio de segurança que garante que a informação esteja disponível para acesso por pessoas e meios autorizados no momento em que forem requisitados. Alguns casos clássicos da falta de disponibilidade podem ser entendidos como sistemas fora do ar, perdas de documentos ou perda de acesso à informação.

É importante observar que a segurança da informação não está relacionada somente com sistemas de informação e dispositivos computacionais, mas a qualquer ativo que contenha informação. Dessa forma, instalar um antivírus em um *desktop* é uma medida de segurança da informação, assim como inserir controle de acesso em todos os sistemas empresariais, por exemplo.

Tudo bem até aqui? Vamos evoluir com esses conceitos? Bom, precisamos atentar que, além de *hardware* e *software*, existem outros ativos para os quais devem ser mantidos meios de proteção, tais como:

1.4 Pessoas

Ao trabalhar em uma organização, um funcionário adquire informações que podem ser confidenciais e que precisam ser preservadas. Para tanto, uma possível medida de segurança poderia ser solicitar que o profissional assine um termo de confidencialidade por meio do qual o funcionário se compromete formalmente em não revelar essas informações a pessoas fora da empresa.

1.5 Documentos impressos

Em geral, nas empresas, é comum que sejam administrados documentos como boletos, notas fiscais ou cópias de contracheque. Se determinados documentos são extraviados, isso pode significar vazamento dessa informação, e a empresa pode sofrer diversos impactos graves, como multas e processos judiciais. Uma forma de evitar essas ocorrências pode ser utilizar uma administração dos documentos mais importantes por meio de inventários que registram todo o controle desses ativos.

1.6 Ambientes

Existem ambientes físicos dentro das empresas nos quais são expostas informações relacionadas a altos níveis de confidencialidade. A sala de reunião da diretoria é um exemplo. Já outros ambientes incluem, além da confidencialidade, critérios como integridade e disponibilidade, como é o caso do CPD (central de processamento de dados). Medidas de segurança da informação precisam ser estabelecidas e executadas para prevenir o acesso de pessoas não autorizadas a esses ambientes.

ROLÊ 2 – VULNERABILIDADES E CIBERSEGURANÇA

Segundo Dantas (2011), vulnerabilidades são fragilidades que podem provocar danos presentes ou futuros para as pessoas e as organizações. A NBR ISO/IEC 27002 define a vulnerabilidade como uma fragilidade de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças (Brasil, 2013).

Mas o que é uma ameaça? Ameaças são agentes externos ao ativo de informação que exploram as vulnerabilidades para gerar a quebra de um ou mais dos três princípios básicos da segurança da informação (confidencialidade, integridade e disponibilidade), ou seja, quando ocorre um incidente de segurança da informação. Mas o que é um incidente de segurança da informação? É a ocorrência de um evento que possa interromper os processos do negócio. Entendidos os conceitos de vulnerabilidade, ameaça e incidente, vamos resumir dando um exemplo para tentar deixar esses conceitos mais claros: imagine que estamos com a imunidade baixa (vulnerabilidade) e existe um vírus no ar (ameaça) e que, com isso ficamos gripados (incidente).

Dantas (2011) afirma que as vulnerabilidades podem envolver vários aspectos, tais como: instalações físicas desprotegidas contra incêndio, inundações, acessos indevidos e desastres naturais; material inadequado empregado nas construções; ausência de políticas de segurança para RH; funcionários sem treinamento e insatisfeitos nos locais de trabalho; ausência de procedimentos de utilização de equipamentos; equipamentos sem manutenção adequada e sem restrições para sua utilização; *software* desatualizados e sem licença de funcionamento, entre outros. Logo, podemos classificar as vulnerabilidades com base em sua origem, da seguinte forma: em naturais,



organizacionais, físicas, de *hardware*, de *software*, nos meios de armazenamento, humanas e nas comunicações.

Reforçando o que acabamos de discutir, uma vulnerabilidade pode ser explorada por uma ameaça para concretizar um ataque aos sistemas de uma empresa. Isso nos leva a buscar entender o que é cibersegurança.

A cibersegurança, que também pode ser chamada de *segurança cibernética*, é a prática de proteger informações e dados que chegam à organização, vindas de fontes externas por meio de protocolos de internet. Ou seja, é a segurança cibernética que procura proteger a rede das empresas de invasões externas. Reforçando, a cibersegurança trata exclusivamente da proteção de dados e informações que se baseiam em fontes externas, provenientes da internet.

Dessa forma, nem tudo que é segurança da informação envolve a cibersegurança, mas toda cibersegurança envolve a segurança da informação. Isso precisa ficar bem claro.

Algumas boas práticas que podem ser seguidas pelas empresas envolvem as seguintes ações: evitar e combater ataques virtuais, identificar e recuperar vulnerabilidades nos sistemas de TI, proteger dados armazenados virtualmente, determinar regras para a gestão das informações, controlar o acesso de usuários aos dados corporativos.

TRILHA 1 – SEGURANÇA DIGITAL

Já percebeu que o mundo está mais perigoso e que estamos cada vez mais ouvindo falar em ataques cibernéticos? Pois é, as ameaças à segurança das empresas aumentam quase que na mesma proporção que as inovações chegam ao mercado.

Várias empresas e seus empresários estão investindo na expansão e na inovação dos seus negócios, o que os leva a se preocupar também com os aspectos da segurança. Não se preocupar com segurança ou tentar economizar nesse quesito pode expor a empresa a ataques mal-intencionados, gerando prejuízos incalculáveis.

As informações de uma empresa, sejam elas digitalizadas ou não, estão no centro de qualquer negócio, sendo um ativo de grande valor e um diferencial competitivo. Os registros de informação, tanto os dados pessoais de fornecedores, clientes ou colaboradores quanto a propriedade intelectual da



empresa podem ser mantidos em vários lugares e acessados de diversas maneiras, por isso, um bom plano de segurança da informação deve contemplar todas as informações e o plano para garantia de cada uma.

Mas vocês acham que podemos prever tudo e garantir segurança total em todos os sistemas da empresa? Bom, a resposta, infelizmente, é não.

É fundamental compreender que nenhuma empresa é capaz de atingir um nível de controle total das ameaças à segurança da informação, e um dos principais motivos é a constante dinâmica da inovação na evolução de *hardwares* e *softwares*. Ou seja, apesar de ser fundamental para a economia, a constante evolução da tecnologia agrega um grande risco à segurança da informação.

Alguns especialistas do mercado avaliam que as transformações na segurança digital demandarão novos tipos de estratégias e habilidades para superar os ataques cada vez mais bem elaborados que estão surgindo. Além disso, eles advertem sobre a impossibilidade de tratar todas as ameaças de forma igual, por isso, é necessário priorizar o que é mais importante e possui maior risco para a empresa.

É fundamental cuidar dos investimentos em segurança da informação, pois é preciso atuar na prevenção e na localização de vulnerabilidades, buscando identificar, superar e resolver os problemas o mais rápido possível.

Percebe os desafios que as equipes de segurança digital enfrentam no dia a dia? Essas equipes devem se adaptar rapidamente às inovações e às condições necessárias para a continuidade dos negócios e, ao mesmo tempo, precisam estar preparadas para enfrentar ameaças cada vez maiores, em um ambiente progressivamente crítico e hostil.

Isso nos leva a compreender que os profissionais da área devem aprender a trabalhar com as principais e mais modernas tendências tecnológicas, pois assim podem tentar manter a proteção de todos os sistemas da organização. Não vejam isso como um problema, mas sim como oportunidades para nós, profissionais de TI!

TRILHA 2 – LEI GERAL DE PROTEÇÃO DE DADOS – LGPD

Os problemas gerados pelas vulnerabilidades são tão grandes e críticos que até mesmo as autoridades legais de vários países estão preocupadas com a proteção das informações das pessoas e das empresas.



Segundo a Wikipedia (2020), a Lei Geral de Proteção de Dados Pessoais (LGPD ou LGPDP), Lei n. 13.709/2018, é “a legislação brasileira que regula as atividades de tratamento de dados pessoais e que também altera os arts. 7º e 16 do Marco Civil da Internet”.

De acordo com o Serpro (Serviço Federal de Processamento de Dados) O que é..., (2018), a LGPD é a Lei n. 13.709/2018, com vigência a partir de agosto de 2020. A nova lei busca criar um cenário de segurança jurídica, com a padronização de normas e práticas, para promover a proteção, de forma igualitária e dentro do país e no mundo, aos dados pessoais de todo cidadão que esteja no Brasil.

A LGPD vai além e estabelece ainda que não importa se a sede de uma organização está localizada no Brasil ou no exterior. Havendo processamento de informações de pessoas, brasileiras ou não, que estão no território nacional, a lei deve ser cumprida pela empresa. Pela lei é permitido compartilhar dados com organismos internacionais e com outros países, mas para que isso ocorra, devem ser seguidos protocolos seguros que cumpram as exigências legais.

Ou seja, de empresas de compras *on-line* a redes sociais, de hospitais a bancos, de escolas a teatros, de hotéis a órgãos públicos, da publicidade à tecnologia, todas serão afetadas pela LGPD. Independente do setor da economia ou do tipo de serviços que presta a seus clientes, a empresas precisam se preparar para atender às exigências legais. E como as empresas precisam se preparar?

Resumindo os pontos principais que deverão ser tratados pelas empresas para estar aderentes à LGPD, podemos citar a questão do *consentimento*, que envolve o consentimento do cidadão/cliente para que os dados pessoais possam ser tratados pelas empresas, e a *automatização com autorização*, o que permite aos clientes solicitar que dados sejam deletados, solicitar revogação de um consentimento, solicitar transferência dados para outro fornecedor de serviços, entre outras ações. Esclarecendo melhor esse ponto, se a finalidade de um tratamento, feito exclusivamente de modo automatizado, for construir um perfil (pessoal, profissional, de consumo, de crédito), o cliente deve ser informado que pode intervir, pedindo revisão desse procedimento feito por máquinas.

Para garantir o cumprimento da lei, foi criada a ANPD (Autoridade Nacional de Proteção de Dados Pessoais), que tem como objetivo regular e



orientar, preventivamente, sobre como aplicar a lei, fiscalizar as empresas e, se a LGPD for descumprida, penalizar.

Portanto, o papel da TI no meio desse processo de adequação à LGPD é apoiar as empresas desenvolvendo e disponibilizando formas de garantir o cumprimento da lei.

Além disso, um mundo de novas demandas se abre para os profissionais da TI quando pensamos nas necessidades geradas pelo aumento de ameaças que surgem todo dia no meio tecnológico. Precisamos estar prontos para aproveitar estas oportunidades.

Saiba mais

Para saber mais sobre o mercado de segurança da informação, acesse o *link* a seguir e leia o artigo sobre esse tema:

PREVISÃO 2020: América Latina deve crescer 12% em segurança da informação. **ComputerWorld**, 31 mar. 2020. Disponível em: <<https://computerworld.com.br/2020/03/31/previsao-2020-america-latina-deve-crescer-12-no-mercado-de-seguranca-de-ti/>>. Acesso em: 23 abr. 2020.

ELO

Como estudamos nesta aula, a segurança da informação envolve várias ações diferentes com o objetivo de garantir a proteção dos dados, seja por meios tecnológicos, seja pela conscientização das pessoas.

Ficou claro que os dados importantes e sigilosos das empresas são, na maior parte das vezes, armazenados digitalmente? Logo, a preocupação com a segurança da informação é extrema e cada vez mais exige investimento das empresas. O risco de criminosos virtuais acessarem essas informações ou provocarem a perda dos dados faz com que muitas empresas utilizem medidas e ferramentas de proteção, de forma a garantir o gerenciamento efetivo dos riscos de um incidente de segurança.

Saiba mais

Achou esse assunto interessante? Para se aprofundar no tema, acesse os *links* a seguir e assista aos vídeos para compreender como atua e como se preparar para atuar profissionalmente na área de segurança da informação:



1. O QUE FAZ um analista de segurança da informação? **Canal TI**, 10 abr. 2018. Disponível em: <<https://www.youtube.com/watch?v=zUNvT-Ecdhg>>. Acesso em: 23 abr. 2020.

2. COMO INICIAR uma carreira em segurança da informação? Bate papo com @Daniel Donda. **Léo Andrade**, 23 maio 2018. Disponível em: <<https://www.youtube.com/watch?v=p2jO7l06wB0>>. Acesso em: 23 abr. 2020.

REFERÊNCIAS

ABNT – Associação Brasileira de Normas Técnicas. **NBR ISO/IEC 27002:2013**. Tecnologia da informação. Técnicas de segurança – Código de prática para controles de segurança da informação. Rio de Janeiro: ABNT, 2013.

DANTAS, M. L. **Segurança da informação**. Pernambuco: Livro Rápido, 2011.

ISO/IEC 27000: norma internacional de segurança da informação é revisada. **ABNT**, S.d. Disponível em: <<http://www.abnt.org.br/noticias/5777-iso-iec-27000-norma-internacional-de-seguranca-da-informacao-e-revisada>>. Acesso em: 23 abr. 2020.

O QUE É a Lei Geral de Proteção de Dados Pessoais? Dê um giro pela lei e conheça desde já as principais transformações que ela traz para o país. **Serpro**, 2018. Disponível em: <<https://www.serpro.gov.br/lgpd/menu/a-lgpd/o-que-muda-com-a-lgpd>>. Acesso em: 23 abr. 2020.

ROMIO, D. Como executivos devem investir em segurança da informação? **CIO**, 14 ago. 2019. Disponível em: <<https://cio.com.br/como-executivos-devem-investir-em-seguranca-da-informacao/>>. Acesso em: 23 abr. 2020.

WIKIPEDIA. Lei Geral de Proteção de Dados Pessoais. **Wikipedia**, 8 abr. 2020. Disponível em: <https://pt.wikipedia.org/wiki/Lei_Geral_de_Prote%C3%A7%C3%A3o_de_Dados_Pessoais>. Acesso em: 23 abr. 2020.